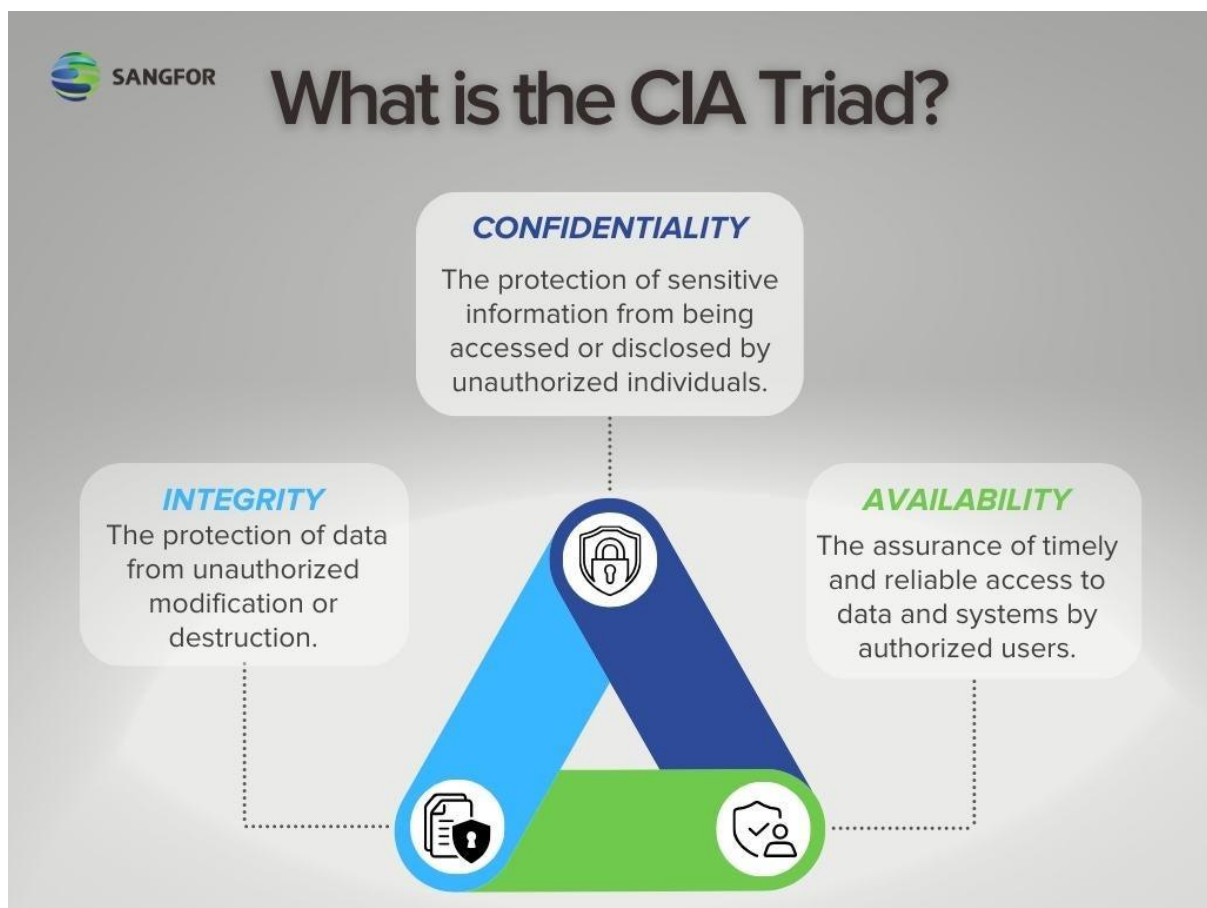


CYBERSECURITY

Cybersecurity is the practice of protecting digital devices, networks, and sensitive data from threats like hacking, malware, and phishing. Also known as Information Security (INFOSEC), Information Assurance (IA), or System Security.

CIA Triad (Confidentiality, Integrity, Availability)

The **CIA Triad** is a core cybersecurity model used to protect information systems. It focuses on **keeping data secret, accurate, and accessible**.



CIA Triad in Banking System (Real-World Examples)

CYBERSECURITY

1 Confidentiality

Meaning: Only authorized users can access sensitive data.

Banking Example:

- Your **ATM PIN, net banking password, and account balance** are encrypted.
 - Technologies used: **Encryption, OTP, MFA (Multi-Factor Authentication)**
✓ *Prevents hackers from reading your bank data.*
-

2 Integrity

Meaning: Data should not be altered without authorization.

Banking Example:

- If you transfer **₹10,000**, it must not change to **₹1,00,000** during processing.
 - Technologies used: **Hashing, digital signatures, transaction logs**
✓ *Ensures transaction data remains accurate.*
-

3 Availability

Meaning: Systems must be accessible when needed.

Banking Example:

- ATM services and mobile banking should work **24/7**, even during high traffic.
- Technologies used: **Load balancers, backups, failover servers**
✓ *Ensures customers can access money anytime.*

Different Types of Cyber Attackers

(Explained clearly, with real-world context, based on commonly cited security research & blogs like OWASP, Kaspersky, CrowdStrike, and Cisco)

CYBERSECURITY

1 Script Kiddies

Who they are:

- Beginners with **little or no technical knowledge**
- Use **pre-written tools, scripts, and exploits** downloaded from the internet

Motivation:

- Fun, curiosity, showing off, boredom

Capabilities:

- Low skill
- Can still cause damage using tools like DDoS scripts or vulnerability scanners

Real-World Example:

- Running a DDoS attack on a gaming server using a free tool
- Defacing a small website using a copied exploit

Threat Level: ● Low to Medium

✅ *Even low-skilled attackers can be dangerous if systems are poorly secured.*

2 Insider Attackers

Who they are:

- Employees, ex-employees, contractors, or partners
- Already have **authorized access**

Motivation:

- Revenge

CYBERSECURITY

- Financial gain
- Negligence (accidental insider threat)

Capabilities:

- High access
- Know internal systems and weaknesses

Real-World Example:

- Bank employee leaking customer data
- IT admin deleting critical servers before resigning

Threat Level: ● ● ● High

⚠ *Considered one of the most dangerous threats because security controls often trust insiders.*

3 Hacktivists

Who they are:

- Attackers driven by **political, social, or ideological motives**

Motivation:

- Protest
- Public awareness
- Revenge against organizations or governments

Common Attack Methods:

- Website defacement
- DDoS attacks
- Data leaks (doxxing)

Real-World Example:

- Attacking government websites during protests
- Leaking corporate emails to expose alleged wrongdoing

CYBERSECURITY

Threat Level: ● ● Medium to High

🚩 *Their goal is visibility and impact, not money.*

4 Nation-State Attackers (APT Groups)

Who they are:

- Government-sponsored, highly skilled cyber teams

Motivation:

- Espionage
- Cyber warfare
- Economic or political advantage

Capabilities:

- Very high skill
- Zero-day exploits
- Long-term stealth attacks (APT – Advanced Persistent Threats)

Real-World Example:

- Targeting power grids, defense systems, elections
- Cyber espionage against other countries

Threat Level: ● ● ● ● Very High

🛡️ *Only strong national-level defenses can handle these attackers.*

5 Cybercriminals (Bonus – Very Common in Exams)

Who they are:

- Organized crime groups

Motivation:

- 💰 Financial gain

CYBERSECURITY

Common Attacks:

- Ransomware
- Phishing
- Credit card fraud

Real-World Example:

- Ransomware attacks on hospitals
- Phishing emails stealing banking credentials

Threat Level: ● ● ● High

CYBERSECURITY

Common Attack Surfaces in Cybersecurity

An **attack surface** refers to **all possible entry points** where an attacker can attempt to access, exploit, or compromise a system.

1 Web Application Attack Surface

What it is

The **web attack surface** includes websites, portals, admin panels, login forms, and backend servers accessible through browsers.

Why it is vulnerable

- Publicly exposed to the internet
- Often handles **user input** (forms, URLs, cookies)
- Frequent coding mistakes

Common Attack Vectors

- **SQL Injection** – manipulating database queries
- **Cross-Site Scripting (XSS)** – injecting malicious scripts
- **Cross-Site Request Forgery (CSRF)** – forcing users to perform actions
- **Broken Authentication & Session Management**
- **File Upload Vulnerabilities**

Real-World Impact

- Website defacement
- User data theft
- Account takeovers

Typical Defenses

- Input validation and output encoding
- Web Application Firewalls (WAF)
- Secure authentication mechanisms

CYBERSECURITY

- Regular security testing (VAPT)
-

2 API Attack Surface

What it is

APIs allow **applications to communicate** with each other and are commonly used in **mobile apps, microservices, and cloud platforms**.

Why it is vulnerable

- Often exposed publicly
- Weak authentication and authorization
- Excessive data exposure

Common Attack Vectors

- **Broken Object Level Authorization (BOLA)**
- **Broken Authentication**
- **Mass Assignment**
- **Rate-limit bypass**
- **API Injection attacks**

Real-World Impact

- Unauthorized data access
- Data scraping
- Business logic abuse

Typical Defenses

- Strong API authentication (OAuth 2.0, JWT)
 - Proper authorization checks
 - Rate limiting & throttling
 - API gateways
-

CYBERSECURITY

3 Mobile Application Attack Surface

What it is

Includes **Android/iOS apps**, local storage, backend APIs, and communication channels.

Why it is vulnerable

- Apps run on **untrusted devices**
- Reverse engineering is possible
- Weak client-side security

Common Attack Vectors

- **Insecure local storage** (tokens, credentials)
- **Hardcoded secrets**
- **Insecure API communication**
- **Weak certificate pinning**
- **Reverse engineering & tampering**

Real-World Impact

- Account hijacking
- Leakage of personal data
- Malware injection

Typical Defenses

- Secure storage (Keychain/Keystore)
- Encryption for data in transit & at rest
- Obfuscation & anti-tampering
- Secure backend validation

4 Cloud Infrastructure Attack Surface

What it is

CYBERSECURITY

Includes **cloud services, virtual machines, containers, storage, IAM policies, and management consoles.**

Why it is vulnerable

- Misconfigurations
- Over-privileged identities
- Shared responsibility confusion

Common Attack Vectors

- **Misconfigured storage buckets**
- **Exposed management ports**
- **Compromised IAM credentials**
- **Container escape attacks**
- **Supply chain attacks**

Real-World Impact

- Massive data breaches
- Cryptomining attacks
- Complete cloud account takeover

Typical Defenses

- Principle of least privilege (IAM)
- Continuous configuration monitoring
- Network segmentation
- Logging & monitoring (SIEM, CSPM)

CYBERSECURITY

OWASP Top 10 Web Application Vulnerabilities

1 Broken Access Control

Description:

Occurs when users can act outside their intended permissions, such as accessing admin features or other users' data.

Example:

A normal user accessing /admin pages.

2 Cryptographic Failures

Description:

Sensitive data is exposed due to weak or missing encryption.

Example:

Passwords stored in plain text or weak hashing algorithms.

3 Injection

Description:

Untrusted data is sent to an interpreter, causing unintended execution of commands.

Example:

SQL Injection, Command Injection, LDAP Injection.

4 Insecure Design

Description:

Flaws in application architecture or business logic that cannot be fixed by code alone.

Example:

No limit on login attempts (brute-force allowed).

CYBERSECURITY

5 Security Misconfiguration

Description:

Improper security settings, default credentials, or unnecessary services enabled.

Example:

Admin consoles exposed to the internet.

6 Vulnerable and Outdated Components

Description:

Using libraries, frameworks, or software with known vulnerabilities.

Example:

Running an old version of Apache or Log4j.

7 Identification and Authentication Failures

Description:

Weak authentication mechanisms allow attackers to compromise accounts.

Example:

Weak passwords, no MFA, session fixation.

8 Software and Data Integrity Failures

Description:

Application relies on untrusted software updates or data without verification.

Example:

Compromised CI/CD pipeline or malicious updates.

9 Security Logging and Monitoring Failures

Description:

Lack of logging and monitoring prevents detection of attacks.

Example:

Brute-force attacks not logged or alerted.

CYBERSECURITY

10 Server-Side Request Forgery (SSRF)

Description:

Attacker tricks the server into making requests to internal or external systems.

Example:

Accessing internal cloud metadata services.

Mapping Daily-Use Applications to Attack Surfaces

1 Email Applications (Gmail, Outlook, Yahoo Mail)

Main Attack Surfaces

- **Web Interface** (browser-based email access)
- **Mobile Application**
- **Email Protocols** (SMTP, IMAP, POP3)
- **Attachments & Links**
- **Authentication System**

Possible Attacks

- Phishing emails & credential harvesting
- Malicious attachments (malware, ransomware)
- Account takeover via weak passwords
- Session hijacking
- OAuth abuse

Example Scenario

A user clicks a **fake login link** → enters credentials → attacker gains full email access.

CYBERSECURITY

2 WhatsApp (Messaging Apps)

Main Attack Surfaces

- **Mobile App (Android / iOS)**
- **Backend APIs**
- **Media Handling (Images, Videos, Voice Notes)**
- **Backup Storage (Cloud backups)**
- **Account Registration (OTP-based auth)**

Possible Attacks

- Account takeover via **SIM swapping**
- Malicious media file exploitation
- Insecure cloud backups (Google Drive / iCloud)
- Social engineering through fake messages
- Spyware targeting messaging apps

Example Scenario

Attacker performs **SIM swap** → receives OTP → hijacks WhatsApp account.

3 Banking Applications (Mobile & Internet Banking)

Main Attack Surfaces

- **Mobile Banking App**
- **Web Banking Portal**
- **APIs connecting app to bank servers**
- **Authentication & Authorization Layer**
- **Transaction Processing System**

Possible Attacks

- Phishing (fake bank SMS / emails)

CYBERSECURITY

- Malware on mobile devices
- Man-in-the-Middle (MITM) attacks
- API abuse (broken authorization)
- Credential stuffing

Data Flow from User to Server to Database

1. User Layer (Client Side)

Description

The **user layer** is where data originates. It includes:

- Web browsers (Chrome, Firefox)
- Mobile applications
- Desktop applications

Data Involved

- Login credentials (username, password, OTP)
- Form data (registration, payments, messages)
- Requests (search, upload, update)

Process

1. User enters data in a form or app interface
2. Data is validated at the client side (basic checks only)
3. A request is created using **HTTP/HTTPS**

Security Considerations

- Input validation
 - HTTPS encryption
 - Avoid storing sensitive data on client
-

CYBERSECURITY

2. Network / Transport Layer

Description

This layer transfers data from the user device to the server over the internet.

Process

1. Client sends an **HTTP request** (GET, POST, PUT, DELETE)
2. Request travels through:
 - ISP
 - Routers
 - Firewalls
3. Data reaches the application server

Security Considerations

- TLS/SSL encryption
 - Protection against MITM attacks
 - Network firewalls
-

3. Application Server Layer

Description

The **server layer** processes business logic and controls access to data.

Components

- Web server (handles HTTP requests)
- Application logic (authentication, authorization)
- API services

Process

1. Server receives request
2. Validates user authentication (session, token, OTP)
3. Checks authorization (user permissions)

CYBERSECURITY

4. Sanitizes and validates input
5. Prepares a database query

Security Considerations

- Authentication & authorization checks
 - Input sanitization
 - Rate limiting
 - Logging and monitoring
-

4. Database Layer

Description

The **database** stores structured or unstructured data.

Types of Data Stored

- User profiles
- Transactions
- Messages
- Logs

Process

1. Server sends a query (SELECT, INSERT, UPDATE, DELETE)
2. Database executes the query
3. Data is fetched or modified
4. Result is returned to the server

Security Considerations

- Access control (DB users & roles)
- Encryption at rest
- Prevention of SQL injection
- Regular backups

CYBERSECURITY

5. Response Flow (Reverse Path)

Process

1. Database sends results to the server
2. Server processes and formats response (JSON / HTML)
3. Response is sent back over HTTPS
4. Client displays the result to the user

Example

User logs in → server validates → database confirms → user dashboard loads

Final Conclusion (Unified Understanding)

After exploring **CIA Triad**, **types of attackers**, **attack surfaces (web, API, mobile, cloud)**, **OWASP Top 10 vulnerabilities**, **daily-use applications**, and **data flow from user to server to database**, the **overall conclusion** is:

Security Is End-to-End, Not One-Layer

Security **cannot be achieved by protecting a single component**.

Every system is only as strong as its **weakest link**—from the **user device** to the **database**.

Key Takeaways (Integrated View)

Data Is the Primary Target

Attackers ultimately aim to:

- **Steal data** (Confidentiality breach)
- **Modify data** (Integrity breach)
- **Disrupt access** (Availability breach)

CYBERSECURITY

➔ This directly maps to the **CIA Triad**, which forms the foundation of all security decisions.

2 Different Attackers Exploit Different Weaknesses

- **Script kiddies** exploit obvious misconfigurations
- **Insiders** abuse trusted access
- **Hacktivists** target visibility and disruption
- **Nation-state attackers** perform long-term, stealthy attacks

➔ Defenses must be **layered**, not attacker-specific.

3 Attack Surfaces Are Everywhere

Modern applications expose multiple surfaces:

- **Web** → user input & sessions
- **APIs** → authorization & data exposure
- **Mobile apps** → client-side trust issues
- **Cloud** → misconfigurations & IAM abuse

➔ More features = **larger attack surface**.

4 OWASP Top 10 Represents the Most Common Failures

Most real-world breaches occur due to:

- Broken access control
- Weak authentication
- Misconfiguration
- Vulnerable components

➔ These are **preventable issues**, not advanced hacking.

CYBERSECURITY

5 Daily-Use Apps Are High-Value Targets

Email, messaging, and banking apps:

- Store sensitive personal and financial data
- Depend on APIs and cloud infrastructure
- Are heavily targeted by phishing and malware

→ User awareness + secure design are equally important.

6 Data Flow Is the Critical Path

From **User** → **Server** → **Database**, every stage must enforce:

- Authentication
- Authorization
- Validation
- Encryption
- Logging

→ A single failure anywhere breaks the entire security chain.